

Incident Response Plan & Cyber Threat Intelligence Analysis

Framework & Actionable Defense Strategy for Public Sector E-Governance Platforms

Candidate: Yuva Intern – NSDC | Domain: Incident Handling, Threat Intelligence & CNI Protection

1. Executive Summary & Scope

Electronic Governance (e-Governance) systems serve as critical national infrastructure (CNI), managing massive volumes of Personally Identifiable Information (PII), sensitive citizen identity documents, financial disbursements, and vital public utility operations. A disruption or compromise within public digital services directly threatens citizen trust, national security, and operational continuity.

This comprehensive document delivers an institutional-grade Incident Response Plan (IRP) aligned with NIST SP 800-61 Rev. 2 and ISO/IEC 27035, integrated with deep Cyber Threat Intelligence (CTI) tailored specifically to the e-Governance ecosystem.

2. Cyber Threat Intelligence (CTI) Analysis for E-Governance

2.1 Threat Actor Landscape

THREAT ACTOR CATEGORY	PRIMARY MOTIVATION	TYPICAL TTPS & TARGET SURFACE	IMPACT LEVEL
Nation-State APTs	Espionage, Strategic Sabotage	Spear-phishing, Zero-day exploitation, Living-off-the-Land (LotL), targeting State Data Centers (SDCs).	Critical
Ransomware Cartels	Financial Extortion, Double-Extortion	Compromised RDP/VPN credentials, encrypting municipal databases & exfiltrating citizen PII.	Critical
Hacktivists	Ideological Disruption, Defacement	Volumetric DDoS against citizen portals, Web defacement, public credential leaking.	High
Malicious / Negligent Insiders	Financial Gain, Accidental Leakage	Abuse of privileged DB access, misconfigured cloud storage (e.g., public S3 buckets).	High

2.2 Specific Attack Vectors & MITRE ATT&CK Mapping

E-Governance architectures rely heavily on interconnected API gateways (e.g., e-Pramaan, DigiLocker, national identity and authentication bridges, unified payment interfaces). These interfaces introduce distinct attack surfaces:

ATTACK VECTOR	MITRE ATT&CK ID & NAME	THREAT MECHANISM IN E-GOV	COUNTERMEASURE
API BOLA	T1190: Exploit Public-Facing Application	Manipulating citizen ID parameters in REST calls to access records belonging to other citizens.	Strict OAuth2 token introspection, schema validation, API rate limiting.
Credential Stuffing	T1110.004: Credential Stuffing	Automated replay of leaked breach combos to hijack citizen welfare & tax accounts.	Adaptive MFA, CAPTCHA integration, WAF behavioral blocking.
Supply-Chain Compromise	T1195.002: Supply Chain Compromise	Exploiting contracted software development agencies to inject backdoors into government portals.	Software Bill of Materials (SBOM), zero-trust network access, strict code signing.

ATTACK VECTOR	MITRE ATT&CK ID & NAME	THREAT MECHANISM IN E-GOV	COUNTERMEASURE
Volumetric & Layer 7 DDoS	T1498: Network Denial of Service	Exhausting server capacity during peak tax/benefit filing deadlines to deny public access.	Anycast DNS routing, automated scrubbing center rerouting, CDN caching.

3. Incident Response Governance & RACI Framework

An effective incident response capability requires unambiguous role allocation across technical, managerial, and legal stakeholders. The following RACI matrix governs incident execution:

PHASE / ACTIVITY	INCIDENT CMDR (CISO)	SOC / IR LEAD	SYS/NET ADMIN	DEVSECOPS	DPO / LEGAL	PUBLIC PR / COMMS
1. Triage & Classification	A	R	C	C	I	I
2. Threat Containment & Isolation	A	R	R	C	I	I
3. Forensics & Evidence Seizure	A	R	C	C	C	I
4. Eradication & Vulnerability Patching	A	C	R	R	I	I
5. Service Restoration & Validation	A	C	R	R	I	I
6. Regulatory / CERT-In Notification	A	C	I	I	R	I
7. Citizen & Media Advisory	A	I	I	I	C	R
8. Post-Incident Review & Lessons Learned	A	R	C	C	C	I

Legend: R = Responsible (doer) | A = Accountable (decision maker) | C = Consulted (subject expert) | I = Informed (kept updated).

4. Step-by-Step Incident Response Lifecycle (NIST SP 800-61)

Phase 1: Preparation

- Logging Architecture:** Centralize logs across all e-Governance tiers (WAF, API Gateway, App Servers, DB clusters) into a tamper-evident SIEM with 1-year hot retention as mandated by CERT-In/national directives.
- Immutable Backups:** Maintain Write-Once-Read-Many (WORM) offsite and air-gapped backups of citizen demographic and transactional databases with automated daily checksum verification.
- EDR & Threat Hunting:** Deploy endpoint detection and response (EDR) agents on all government endpoints and state data center VMs.

Phase 2: Detection, Triage & Severity Classification

Incidents must be triaged within 15 minutes of an automated alert or manual report, mapped to standardized severity levels:

SEVERITY LEVEL	DESCRIPTION & CRITERIA	EXAMPLE SCENARIO	TARGET SLA RESPONSE
P1 - Critical	Mass citizen PII breach (>100k records), active ransomware encrypting government DB, complete portal outage.	Ransomware encryption on Land Registry Cluster.	< 15 minutes

SEVERITY LEVEL	DESCRIPTION & CRITERIA	EXAMPLE SCENARIO	TARGET SLA RESPONSE
P2 - High	Compromised admin credentials, API BOLA exploitation without bulk exfiltration, isolated malware infection.	Privileged admin credential leak on dark web forums.	< 1 hour
P3 - Medium	Localized portal defacement, minor non-critical internal malware alert, repetitive brute force attempts.	Citizen portal header defaced with non-state propaganda.	< 4 hours
P4 - Low	Port scans, blocked phishing emails targeting staff, non-critical policy violations.	Reconnaissance port scan against state gateway IP range.	< 24 hours

Phase 3: Containment Strategy

1. Short-Term Containment:

- **Network Isolation:** Immediately segregate compromised subnets via VLAN ACLs and zero-trust micro-segmentation policies.
- **Token & Session Revocation:** Invalidate all active OAuth tokens, API session keys, and administrative Kerberos tickets across IAM domains.
- **Forensic Snapshotting:** Take full volatile RAM dumps and block-level VM disk snapshots prior to powering down or restarting systems to preserve chain of custody.

2. Long-Term Containment:

- Deploy egress filtering rules blocking established C2 (Command & Control) IP ranges and domains identified via threat feeds.
- Enable enhanced WAF inspection modes to filter malicious payload strings.

Phase 4: Eradication

- **Root Cause Elimination:** Patch identified application vulnerabilities (e.g., SQLi, zero-day CVEs) and harden web server configurations.
- **Malware Removal:** Execute enterprise-wide EDR remediation scripts to purge malicious binaries, persistence registries, cron jobs, and unauthorized shadow admin accounts.
- **Complete Credential Rotation:** Force a global reset of service account passwords, SSH keys, database credentials, and admin MFA tokens.

Phase 5: Recovery & Service Restoration

- **Phased System Rebuild:** Restore systems using verified, cryptographically validated golden images and clean, pre-compromise immutable backups.
- **Data Integrity Verification:** Run automated checksum comparison algorithms across citizen databases to ensure zero unauthorized record tampering or silent data corruption.
- **Enhanced Observation Mode:** Place restored services under continuous 24/7 SOC telemetry monitoring with aggressive alert thresholds for 14 days post-recovery.

Phase 6: Post-Incident Activity & Lessons Learned

- **Post-Mortem Meeting:** Convene mandatory post-incident review within 72 hours of incident closure with all IR team members and stakeholders.
- **Formal Root Cause Analysis (RCA):** Document timeline, attacker TTPs, containment efficacy, and systemic vulnerabilities.

- **Regulatory Compliance Filing:** Submit complete statutory incident disclosure to CERT-In (within the mandatory 6-hour window for critical sectors) and Data Protection Authorities under national data protection laws.
- **Playbook Refinement:** Update SOC detection rules, firewall baselines, and IR playbooks based on gaps identified.

5. Regulatory Frameworks & Academic References

1. **NIST SP 800-61 Rev. 2:** Computer Security Incident Handling Guide, National Institute of Standards and Technology.
2. **ISO/IEC 27035-1/2:2023:** Information technology — Information security incident management.
3. **CERT-In Cyber Security Directions:** Guidelines under Section 70B of the Information Technology Act for mandatory reporting and log retention.
4. **MITRE ATT&CK Framework for Enterprise (v14):** Matrix for mapping public-sector adversarial techniques.
5. **OWASP Top 10 API Security Risks:** Best practice guidelines for citizen-facing REST API gateways.